

MAX 26.20.2 — Аудит безопасности и обзор изменений (база сравнения: 26.18.1)

Объект: ru.oneme.app (основной) / ru.oneme.ap2 (клон), versionName **26.20.2**, стоковый build 6758 **Релиз:** MAX 26.20.2 GP V2 — Mods by JohNick (arm64-v8a + armeabi-v7a, основной + клон, 4 APK) **Дата:** 2026-06-28 **Метод:** статический анализ — baksmali (smali всех 3 dex), AndroidManifest, network_security_config, ресурсы; сборка через pipeline make_v1 с регрессией pytest (168 passed / 0 failed) и smoke-тестом на устройстве (Samsung S25, Android 15). **База движка:** TamTam (ru.ok.tamtam) + VK Calls SDK (WebRTC). Обфускация R8. **База сравнения:** предыдущая стабильная версия мода — **26.18.1 GP**.

> Назначение документа: зафиксировать, что мод нейтрализует в стоке, перечислить функции и показать, **что нового относительно 26.18.1**. V2 относительно V1 — восстановлен «Цифровой ID» (Госуслуги) по реальной причине и оптимизирован сборочный пайплайн (на функции и безопасность не влияет).

ЧАСТЬ 1. Что нового относительно 26.18.1

1.1 Платформа

Версия — полный перенос мода на **свежий сток MAX 26.20.2 (build 6758)**. Все нейтрализации и пользовательские функции портированы по обновлённой R8-карте: при ребилде разработчик переименовал обфусцированные классы, поэтому каждая точка патча сверялась по содержимому (сигнатуры, строковые литералы, якоря), а не по имени. Ключевые смещения имён 26.18.1 → 26.20.2:

Логика	26.18.1	26.20.2
L3 WS chat-event central (антиудаление)	y8b	qya
L4 Room ORM body-clear (антиудаление)	rte	bie
VPN-детектор hasTransport(0x4)	v34	f34
TrustManager accept-all	cy3	dkj
WS redirectHost (MITM)	qde	zf
FCM-диспетчер опасных типов	h5h	egd
JS-bridge verifyMobileId (MSISDN)	naj	z4j
In-call WS (управление записью)	i71	y41
Bottom-nav (порядок вкладок)	j79	z19

1.2 Новые и доработанные функции

- **Новый 15-й переключатель — «Скрыть номер телефона от оператора»** (blockMobileIdVerify). В 26.18.1 было 14 переключателей. Новый блокирует скрытое определение номера через оператора (Header Enrichment / Mobile ID) — запрос MSISDN, уходящий по сотовому каналу. По умолчанию **выключен**. На «Цифровой ID» (Госуслуги) не влияет — это разные механизмы (см. 1.4-a).
- **«При открытии — папка "Новые"»** (startOnNew) **доведён до полноценной работы**. В 26.18.1 функция была частичной. Теперь реализована через observer-хук списка папок (c1/qe3 :pswitch_2b5 → selectStartFolder) и работает как в клоне, так и в основном приложении (см. 1.4-b).

1.3 Изменения в безопасности относительно 26.18.1

- **NSC: операторские HE/Mobile-ID домены заблокированы, гос-эндпоинты оставлены доступными**. В стоке 26.20.2 разработчик расширил привязку номера к гос-системам — добавил cleartext-домены nsc-cdp.voskhod.ru (НИИ «Восход») и nsc-cdp.digital.gov.ru (Минцифры / Цифровой профиль). Операторские домены Header Enrichment / Mobile ID (Мерафон, МТС, Tele2, Билайн) мод переводит в cleartextTrafficPermitted="false" — скрытый MSISDN-запрос по HTTP падает. **Гос-эндпоинты**

намеренно оставлены cleartext-доступными — они задействованы штатной верификацией «Цифрового ID»/Госуслуг, и их блокировка ломала привязку (см. 1.4-а). Управление скрытым запросом номера вынесено на переключатель `blockMobileIdVerify`.

- **FCM-фильтр стал управляемым гейтом** (`gateRemoved`). Типы `MessageRemoved/ChatMessageRemoved` теперь честно соблюдаются при выключенной антиудалёнке (удаление «у всех» работает как в стоке) и блокируются только при включённой — вместо безусловного NOP. Опасные `LocationRequest (silent-GPS)` и `TamTamSpam` блокируются безусловно.

- **Изоляция device_id клона.** Клон (`ru.oneme.ap2`) получает собственный `device_id` (пустая строка в `DeviceIdRemoteDataSource` → клиент генерирует свой UUID), что чинит «удалить у всех» с клона и доставку `push` на клон при общей подписи с основным.

1.4 Исправления (2026-06-28)

(а) Восстановлена работа «Цифрового ID» (Госуслуги/ЕСИА). Симптом: при создании Цифрового ID после авторизации в Госуслугах вместо возврата в MAX открывался браузер с ошибкой **«Не нашли чат по этой ссылке»**. Уже созданный ID при обновлении 26.18.1 → 26.20.2 сохранялся (хранится в данных приложения) — ломалось именно создание/возврат `callback`.

Корневая причина — **побочный эффект приватностного патча P0-2 (myTracker)**. Этот патч нейтрализует трекер VK, обнуляя его инициализацию (`MyTracker.initTracker` → `return-void`). Но MAX использует другой метод того же класса — `MyTracker.handleDeepLink(Intent)` — как **первый шаг разбора любой входящей ссылки** (`LinkInterceptorActivity`). При неинициализированном трекере `handleDeepLink` возвращает `null` («MyTracker hasn't been initialized yet»), и обработчик ссылок уходил в запасной путь на главный экран **без URL** — отсюда «не нашли чат». В 26.18.1 патча P0-2 не было (он добавлен начиная с 26.20.1), поэтому там Цифровой ID работал.

Исправление: `MyTracker.handleDeepLink` заменён на безопасный `passthrough` — возвращает URL напрямую из `Intent (intent.getDataString())`, **без инициализации трекера и без обращений в сеть** (приватность не нарушена, телеметрия по-прежнему мертва). Это чинит **все** внешние ссылки `max.ru` (приглашения, чаты по ссылке, `callback` Госуслуг), а не только Цифровой ID. Точка: `com/my/tracker/MyTracker (sentinel # :p0_2_mytracker_deepink_passthrough)`.

Два сопутствующих условия, без которых `callback` Госуслуг не доходит до приложения:

- **Разрешение ссылок max.ru.** Мод переподписан собственным ключом (иначе его нельзя установить), поэтому Android по умолчанию не доверяет автоматическому открытию ссылок `max.ru` в приложении, и ответ Госуслуг (`https://max.ru/...`) уходит в браузер. Это общее следствие переподписи — касается любого модифицированного MAX. Лечится разовым разрешением (Настройки → Приложения → MAX → «Открывать по умолчанию» → «Открывать поддерживаемые ссылки»). Сборка показывает разовую подсказку с кнопкой перехода в эти настройки (`AppLinkPrompt` на старте). Подробности — в `DIGITAL_ID_README.md`.

- **Cleartext для гос-эндпоинтов** (см. 1.3) — оставлен доступным, иначе шаг верификации обрывается.

> Уточнение: переключатель `blockMobileIdVerify` (патч D2) к этой проблеме отношения **не имеет** — он управляет скрытым MSISDN-запросом через оператора, а не механизмом Госуслуг (подтверждено: переключение тумблера симптом не меняло).

(b) «При открытии — папка "Новые"» теперь работает и в основном приложении. Симптом: папка «Новые» открывалась в свежем клоне, но не в активно используемом основном приложении. Причина — тайминг: приложение восстанавливает последнюю открытую папку (`ChatsTabWidget.onViewCreated` → `getArgs().getString("folder_id")` → выбор по `id`), и это восстановление выполнялось **после** нашего выбора «Новые», перетирая его. В клоне сохранённой папки нет (`folder_id = null` → ранний выход), поэтому выбор выживал. Исправление: восстанавливаемый `folder_id` пропускается через гейт `AppFlags.gateRestoreFolder()` — при включённом `startOnNew` он возвращает `null`, и штатное восстановление само делает ранний выход, не мешая выбору «Новые». Путь `deep-link (onUpdateArgs)` не затронут. Точка: `ChatsTabWidget.onViewCreated (sentinel # :son_restore_gate)`.

1.5 Метрики

- **15** пользовательских переключателей (было 14).

- Регрессия: **pytest 168 passed / 0 failed** (28 skipped, 1 xfailed; база 26.18.1 — 164 теста).
- verify критических слоёв — **0 FATAL**; smali-сборка 3 DEX без VerifyError; 4 APK подписаны (apksigner v2+v3, без v1).
- Smoke на устройстве — **PASS** (включая ручную проверку «Цифрового ID»: привязка через Госуслуги создаётся, и startOnNew в основном приложении).
- Сборочный пайплайн в V2 переведён в декларативный вид: 41 активный шаг патчей + 22 отложенных (по-ор на стоке 26.20.2) вынесены в отдельный реестр. На функции и безопасность не влияет — дерево smali побайтово идентично V1.

ЧАСТЬ 2. Функции (15 переключателей)

Все по умолчанию **выключены** (поведение = сток до первого включения, антидетект). Меню: настройки → «О приложении» → долгий тап.

#	Переключатель	Что делает
1	Антиудаление	Удалённые собеседником сообщения остаются с пометкой «· удалено». 4 слоя (WS-перехват L3 + Room ORM L4 + persistence V3 + маркер), общий гейт antiDelete
2	Антипечатанье	Не отправляет индикатор «печатает...» собеседнику
3	Античиталка	«Прочитано» не передаётся; серверный read-state не сбрасывает локальный
4	Антиприсутствие	Не передаёт last-seen / статус «в сети»
5	Скрыть папку «Всё»	Убирает вкладку-папку «Всё» в списке чатов
6	Скрыть папку «Сферум»	Убирает папку «Сферум» / «Войти в Сферум»
7	Скрыть «MAX для бизнеса»	Убирает рекламную карточку в настройках
8	Скрыть «Пригласить друзей»	Убирает пункт «Пригласить друзей» в настройках
9	Чаты на первом месте	Меняет порядок нижних вкладок (чаты вперёд)
10	При открытии — папка «Новые»	Стартовая папка при запуске — «Новые» (работает и в основном, и в клоне)
11	Автозапуск MAX	Управляет автозапуском после перезагрузки (ВЫКЛ → MAX не стартует в фоне)
12	Улучшить уведомления	WS-reconnect при смене сети; исключение из оптимизации батареи (Xiaomi/Samsung)
13	Основная камера для кружков	Видео-кружки начинаются с основной камеры (по умолчанию фронтальная)
14	Debug-меню звонков	Разблокирует скрытое debug-меню в звонках
15	Скрыть номер телефона от оператора	Новый. Блокирует скрытый MSISDN-запрос через оператора (Header Enrichment / Mobile ID). На «Цифровой ID» (Госуслуги) не влияет

ЧАСТЬ 3. Нейтрализованные угрозы (13 / 13 относительно аудита 26.18.1)

Независимый разбор стока 26.20.2 показал: **все 13 угроз из аудита 26.18.1 присутствуют** в стоке (разработчик ни одну не убрал), а набор cleartext-доменов эскалирован гос-эндпоинтами. Мод нейтрализует каждую.

ID	Угроза в стоке	Как нейтрализовано	Класс (26.20.2)
P0-1	DPS: связка ID+оператор+IP+флаг VPN → trace-flow.ru	stub init провайдера + физическое удаление libtracernative.so	DpsInitProvider, ядро of5

ID	Угроза в стоке	Как нейтрализовано	Класс (26.20.2)
P0-2	myTracker (VK): фингерпринт + root-детект + AD_ID/OAID → vk-analytics.ru	initTracker/trackEvent/flush → return-void; handleDeepLink → passthrough URL (deep-link сохранён, без init/сети)	com/my/tracker/MyTracker
P0-3	WS redirectHost: подмена хоста с TLS off (MITM)	блок применения редиректа (мёртвый код после гейта)	c3/zf (парсер p1e)
P0-4	OneLog: статистика звонков с IP участников → api.ok.ru	метод отправки → return-void	UploadService
P0-5	Серверное управление записью/ASR/микрофоном + аудио-дамп звонка	per-branch гейты + дампы-методы → return-void/null	y41.t(), MediaDumpManagerImpl
P1-3	NFC HCE processCommandApdu отдаёт управление картой мини-аппу	возврат SW [0x6F, 0x00] («command not allowed»)	WebAppNfcService
P1-4	Опасные FCM-типы (Location/Removed/Spam)	gateRemoved (honor при antiDelete OFF) + безусловный блок Location/Spam	c2/egd
P1-5	Авто-выгрузка адресной книги при выходе на foreground	trigger-метод → return-void (все call-sites)	c1/y10.b()
P1-7	TrustManager accept-all (MITM)	throw CertificateException	c3/dkj
D2	JS-bridge verifyMobileId — скрытое определение номера (MSISDN)	гейт за переключатель blockMobileIdVerify (по умолч. ВЫКЛ → штатно; не связан с Цифровым ID)	c3/z4j :cond_2a
N3-H	VPN-детектор hasTransport(0x4) → флаг VPN для DPS	метод → return false	c1/f34.e()
N3-NSC	Операторские HE / Mobile ID домены в cleartext	cleartextTrafficPermitted → false (гос-эндпоинты оставлены доступными для Цифрового ID)	network_security_config.xml
P1-6	Boot autostart (старт в фоне после ребута)	гейт autoStart (по умолчанию ВЫКЛ)	BootCompletedReceiver / BackgroundWakeBootReceiver

Дельта стока относительно 26.18.1: набор HE-доменов обновлён, в сток добавлены **гос-эндпоинты** nuc-cdp.voskhod.ru и nuc-cdp.digital.gov.ru (Цифровой профиль) — эскалация привязки номера к гос-системам. Мод блокирует операторские HE/Mobile-ID домены (MSISDN-привязка), но гос-эндпоинты оставляет доступными — они нужны штатному «Цифровому ID» (см. 1.4-а), а скрытый запрос номера закрывается отдельно (переключатель blockMobileIdVerify + VPN-детектор). Канал dedicated-DPS у разработчика приглушён (авто-init провайдера enabled=false в манифесте), но код цел, а Tracer-телеметрия (appt racer.ru) активна — мод глушит и её.

Нативный слой — чисто: нет детекта root/эмулятора, анти-отладки, скрытой утечки IP. libtracernative (Breakpad) удалён; libmax (QR+Lottie), libEnhancement (шумоподавление), libjingle (WebRTC) не тронуты.

ЧАСТЬ 4. Сборка, подпись, верификация

- **versionName:** 26.20.2; versionCode форсирован в максимум (обновление поверх любой версии).
- **Пакеты:** ru.oneme.app (основной), ru.oneme.ap2 (клон).
- **Подпись:** apksigner Google scheme v2+v3 (без v1); cert SHA-1 d6a7d757...298b — общий со всеми сборками 26.x, что позволяет install -r поверх предыдущих версий без удаления данных.
- **resources.arsc** хранится без сжатия (STORED) — требование Android R+.
- **libtracernative.so** физически удалён из APK.
- **Пайплайн (V2):** декларативный реестр шагов — 41 активный apply-шаг + 22 отложенных (по-оп на текущем стоке, документируются сводкой). Дерево smali побайтово идентично V1; функция и безопасность не изменены.

- **Регрессия:** pytest 168 passed / 0 failed; verify критических слоёв 0 FATAL; smoke на устройстве PASS.

SHA-256 финальных APK

```
f0e0f774840df344ecf514e73fcb11818114abc2805581e0a886103248891fff MAX_26.20.2_arm64_V2.apk
6fc0be88e2a3287c3207e579deaf88b40636865b76fc98d147f8beb8bba819e7 MAX_26.20.2_arm64_V2_clone.apk
346445d7edf0c8989bacd66087839d7546f4e39717f37412ac69bca130f90f51 MAX_26.20.2_arm7_V2.apk
2241ef5423c1692add0bbe7fe857fe304fb55b2bbc5c03ed3c12980a77ccaaba MAX_26.20.2_arm7_V2_clone.apk
```

Документ описывает учебно-исследовательскую модификацию для личного использования. Автор: Mods by JohNick.